Web Application VAPT Report

Target: Perfect Wiki (perfectwikiforteams.com)

Assessor: Mohammed Zia Ur Rahman

Executive Summary

A Web Application Vulnerability Assessment and Penetration Testing (VAPT) engagement was conducted on perfectwikiforteams.com. The assessment identified several security weaknesses across the application's configuration, dependencies, and client-side security controls.

The most critical finding is an outdated version of the Next.js framework (12.3.4), which is vulnerable to a critical authorization bypass (CVE-2025-29927). This allows an attacker to bypass middleware security checks, potentially accessing protected pages or administrative panels without authentication. Additionally, the application is missing several critical HTTP security headers (resulting in a 'D' grade) and issues session cookies without the HttpOnly and Secure flags, exposing users to Cross-Site Scripting (XSS) and session hijacking.

Positively, the application maintains a strong SSL/TLS configuration (A+ rating), a well-configured firewall with minimal exposed ports, and a secure DMARC policy for email. Immediate remediation is recommended for the outdated framework, followed by implementing the missing security headers and cookie attributes to strengthen the overall defense-in-depth posture.

Scope

The scope of this assessment was limited to a black-box security assessment of the external web application perfectwikiforteams.com. The testing focused on identifying security weaknesses in the web application, its supporting infrastructure (ports/services), and its client-side security controls. Testing was performed from an unauthenticated external perspective to simulate an external attacker.

Vulnerabilities Found

The following is a summary of the vulnerabilities and security observations identified during the assessment, categorized by severity:

Severity	Vulnerability	Status
Critical	Outdated JavaScript Library (Next.js 12.3.4 - CVE-2025-29927)	Open
Medium	Missing Security Headers (CSP, X-Frame-Options, etc.)	Open
Medium	Insecure Cookie Configuration (Missing HttpOnly/Secure flags)	Open
Low	Weak SPF Configuration (SoftFail ~all policy)	Open
Informational	SSL/TLS Configuration (A+ Rating)	Pass
Informational	Open Ports (Only 80/443 exposed, 998 filtered)	Pass
Informational	Dotgit Exposure (Not Found)	Pass
Informational	Risky HTTP Methods (TRACE, DEBUG, CONNECT disabled)	Pass

Risky HTTP Methods
Severity: Informational
Affected Component: https://perfectwikiforteams.com

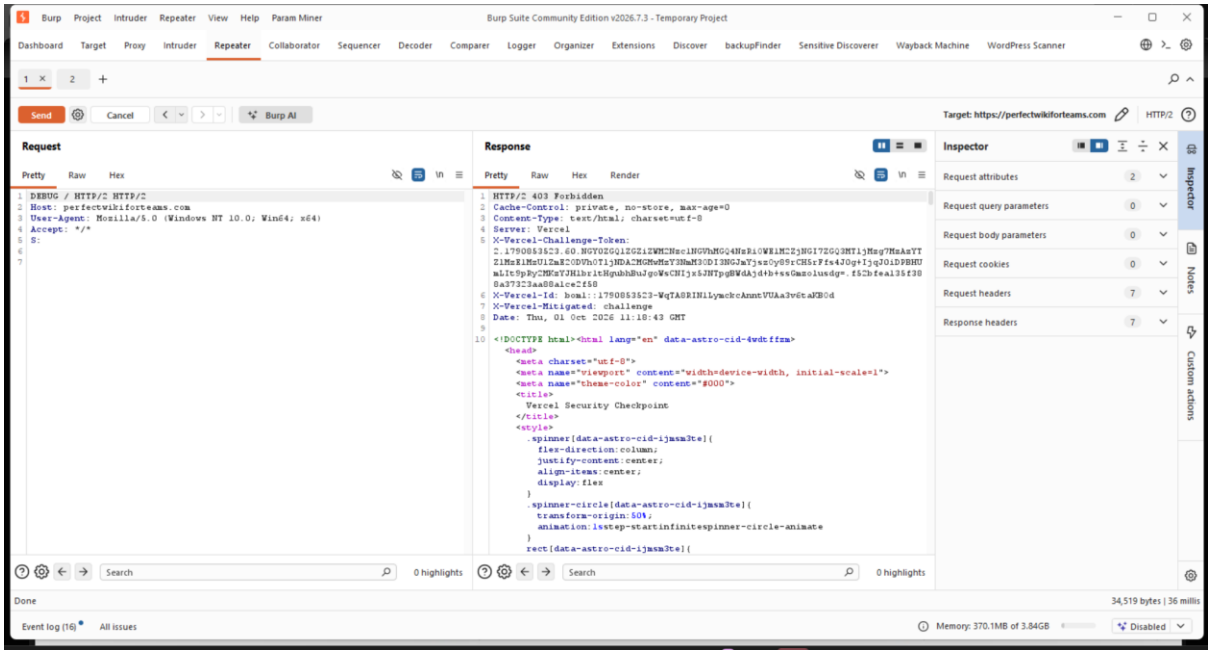
The web server was tested for the presence of potentially dangerous HTTP methods, specifically

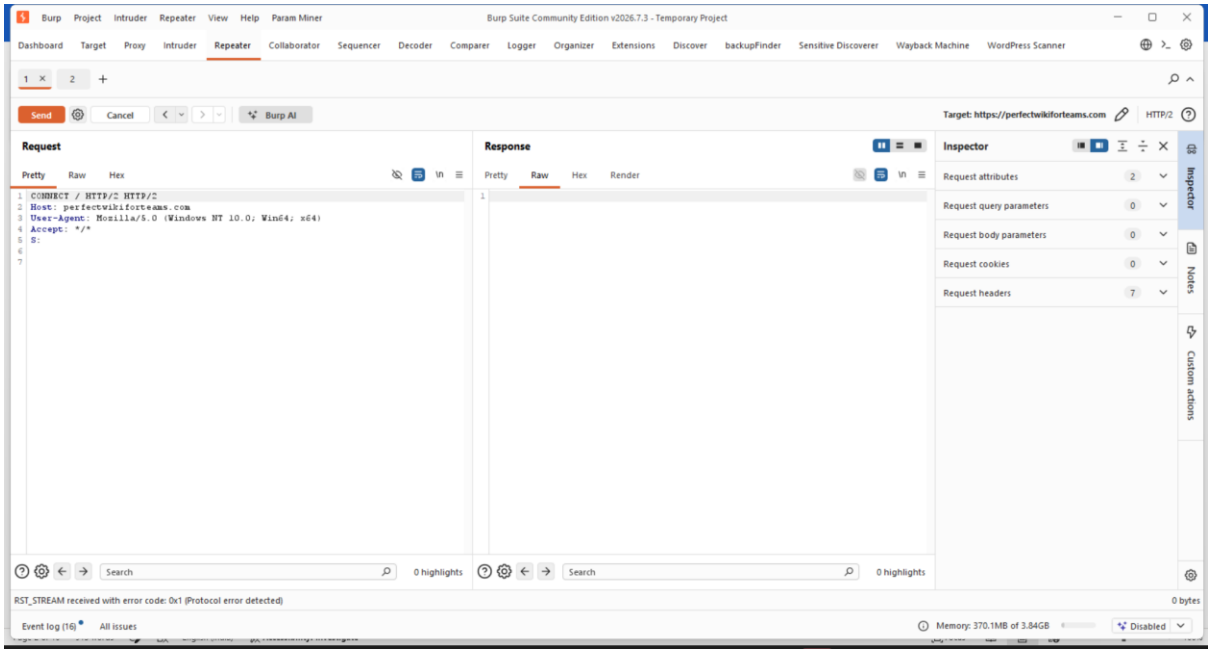
TRACE, DEBUG, OPTIONS, and CONNECT.

Findings: The server was tested with the following methods and returned these results:

- OPTIONS: Returned 200 OK (Standard behavior, informational).
- TRACE: Returned 405 Method Not Allowed (Securely disabled).
- DEBUG: Returned 403 Forbidden (Securely blocked by the WAF).
- CONNECT: Returned no response, indicating the method is not supported (Securely disabled).

Impact: No immediate security risk is presented. The server is securely configured to reject or block dangerous HTTP methods that could otherwise be used for Cross-Site Tracing (XST) or information disclosure.





Missing Security Headers

Severity: Medium

Affected Component: https://perfectwikiforteams.com

Description:

The web application was assessed for the presence of critical HTTP security headers using the securityheaders.com tool. The application received an overall grade of D, indicating several critical headers are missing.

Findings:

The following security headers were found to be missing:

Content-Security-Policy (CSP): Missing. This header helps prevent Cross-Site Scripting (XSS) and data injection attacks by restricting the sources from which scripts and other resources can be loaded.

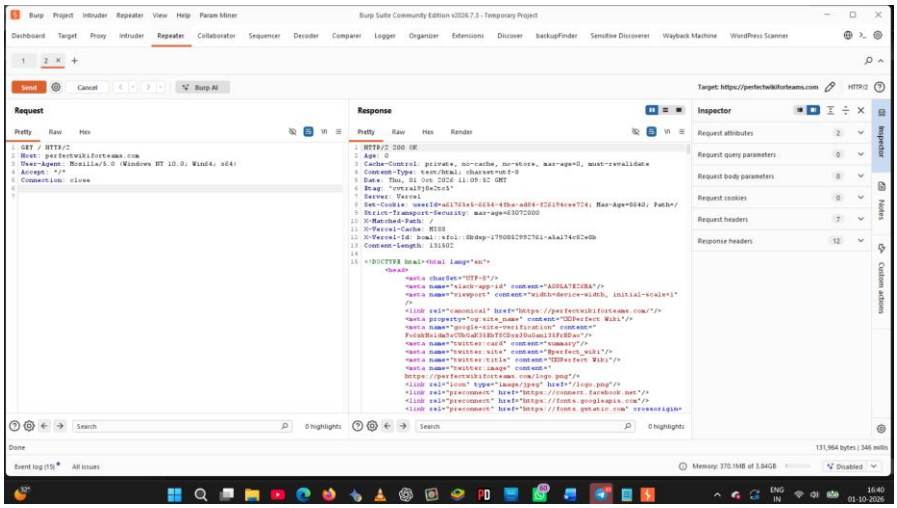
X-Frame-Options: Missing. This header is necessary to protect against Clickjacking attacks, where an attacker embeds the site in an iframe to trick users into clicking hidden elements.

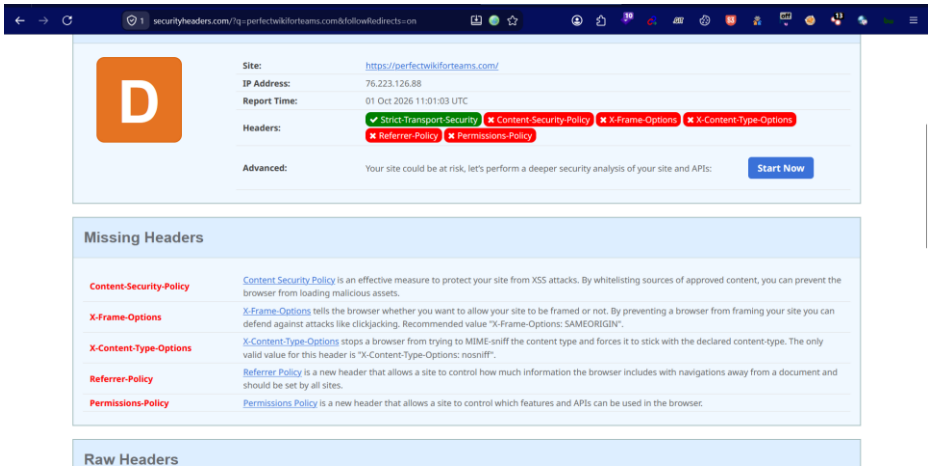
X-Content-Type-Options: Missing. This header prevents the browser from MIME-sniffing a response away from the declared content-type, mitigating drive-by download attacks.

Referrer-Policy: Missing. This header controls how much referrer information is sent with requests, protecting user privacy.

Permissions-Policy: Missing. This header allows the site to control which browser features (like camera, microphone, geolocation) can be used.

The absence of these headers weakens the application's client-side security posture. An attacker could exploit these omissions to execute XSS payloads, trick users into clicking hidden elements (Clickjacking), or bypass browser security controls.



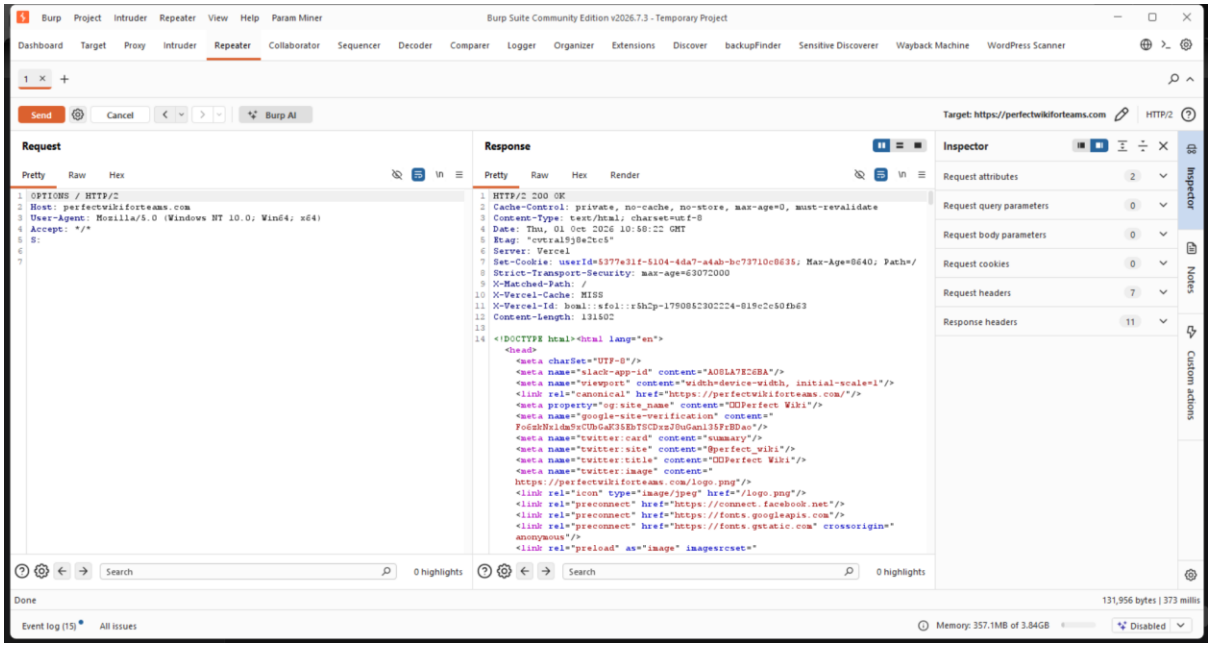


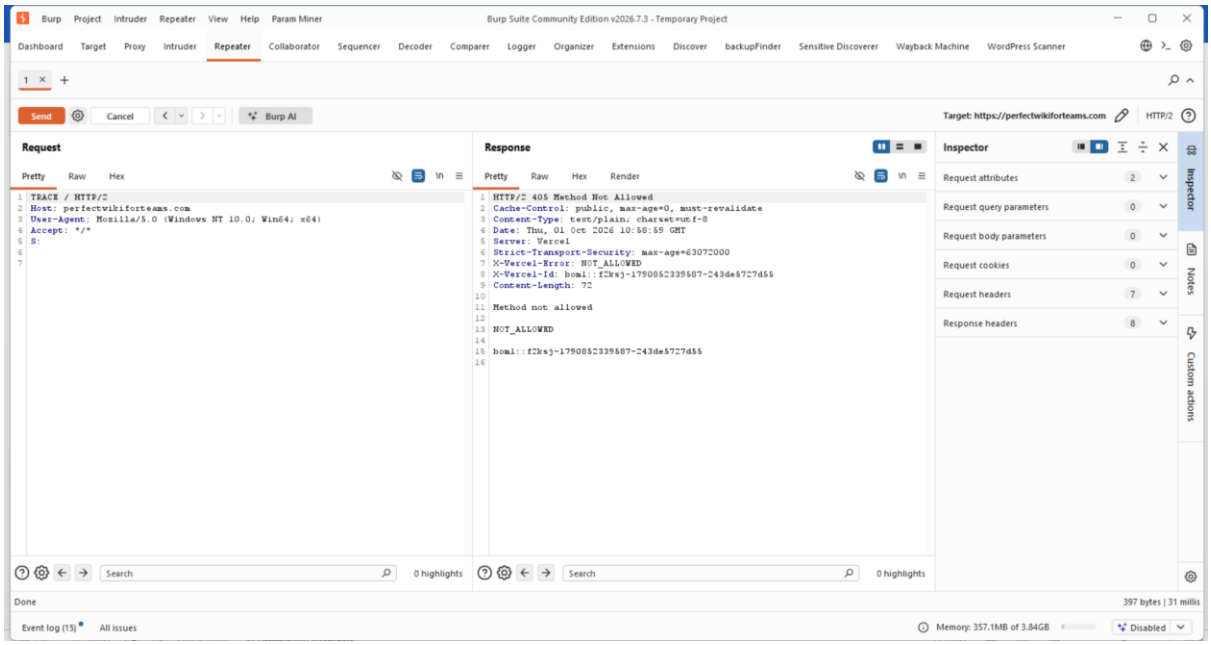
HTTP Method Configuration

Severity: Informational

Description: The web server was tested for the presence of potentially dangerous HTTP methods, specifically TRACE and OPTIONS.

Findings: The server responded to the OPTIONS request with a 200 OK status. The TRACE method returned a 405 Method Not Allowed status, confirming that the server is securely configured to reject this method.





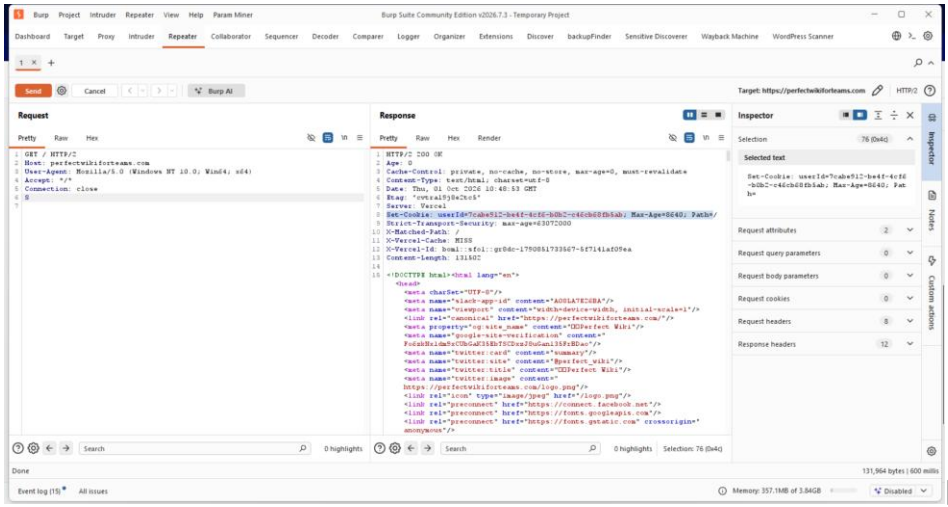
Insecure Cookie Configuration (Missing HttpOnly and Secure Flags)
Affected Component: Session Cookies (userid)

The session cookie issued by the application is missing the HttpOnly and Secure security attributes.

Missing HttpOnly: Allows client-side scripts (JavaScript) to access the cookie.

Missing Secure: Allows the cookie to be transmitted over unencrypted HTTP connections.

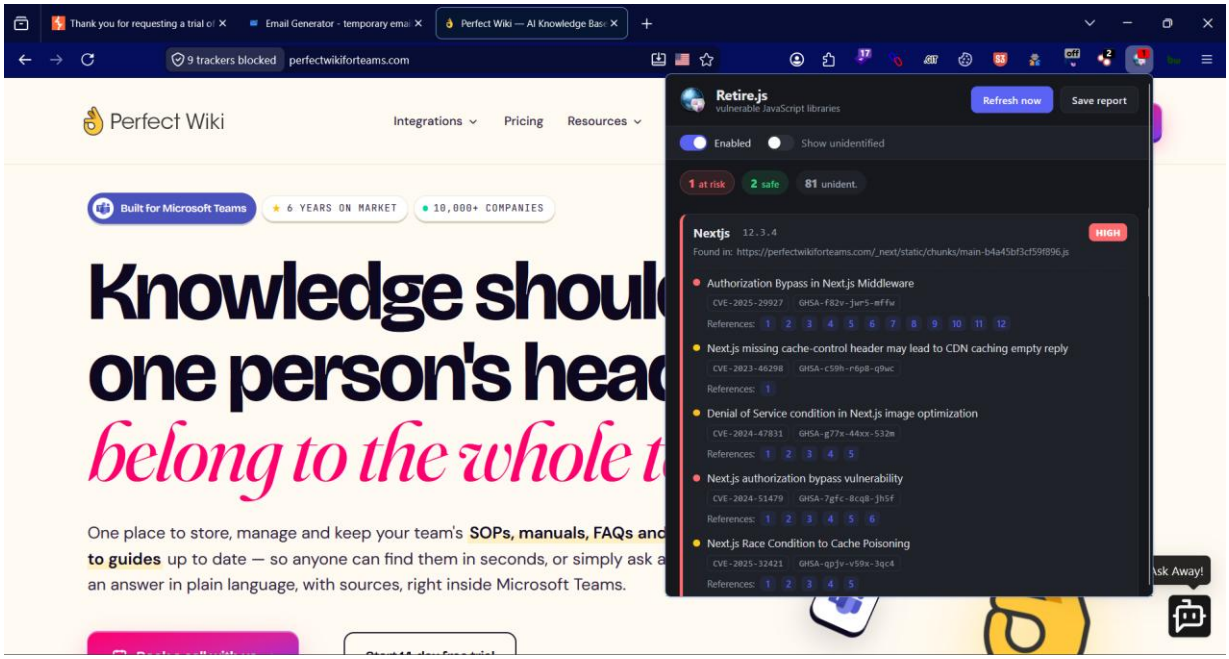
The Set-Cookie header was observed as: Set-Cookie: userid=7cabe912-be4f-4cf6-b0b2-c4e6c68fb5ab; Max-Age=8640; Path=/


b

Perfectwikifor teams.com is using **Next.js version 12.3.4**, which is vulnerable to a critical authorization bypass.

The Impact: If a website's authorization logic (like checking if a user is logged in) is solely in the middleware, an attacker can bypass this and access protected pages or admin panels without any credentials.

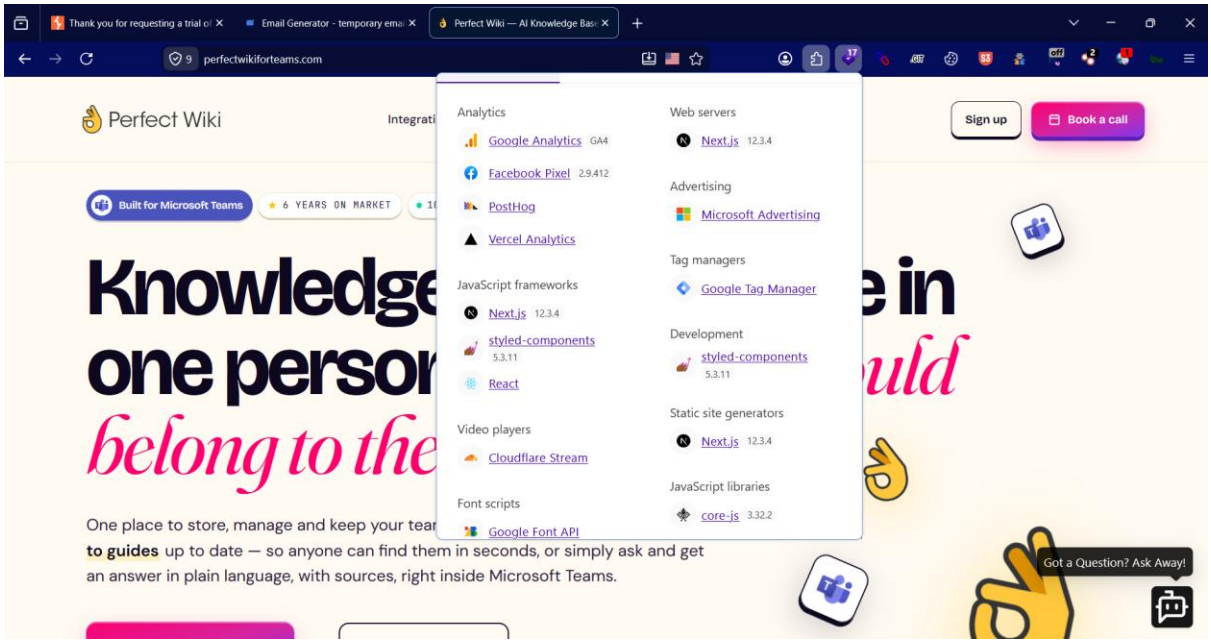
Affected Versions: This vulnerability affects Next.js versions from 11.1.4 up to (but not including) 12.3.5, 13.5.9, 14.2.25, and 15.2.3. The presence of version 12.3.4 on the site makes it vulnerable.



Next.js 12.3.4 (Critical)

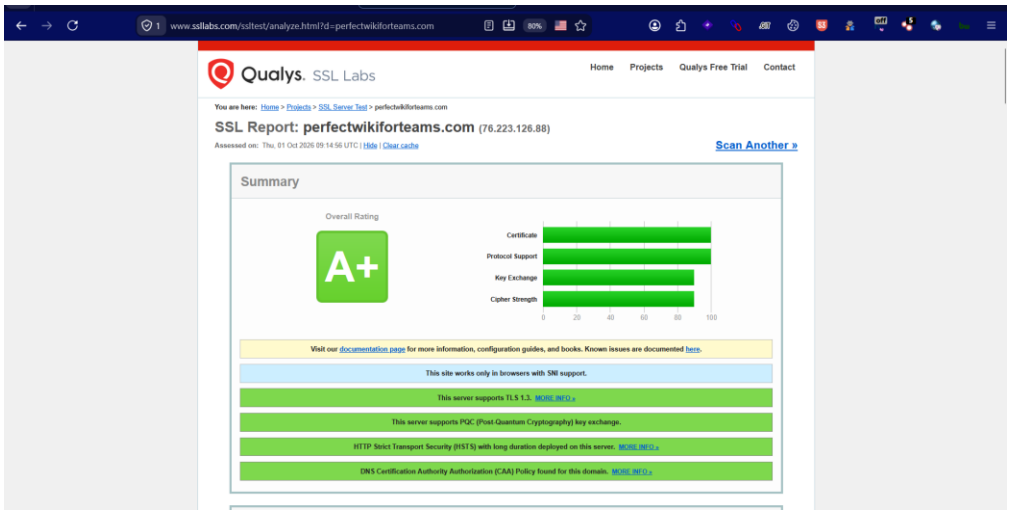
This is the most severe issue. The version in use is vulnerable to **CVE-2025-29927**, a critical authorization bypass flaw.

> It allows attackers to bypass middleware-based security checks, potentially accessing protected pages or admin panels without authentication. It is also susceptible to other flaws, including Server-Side Request Forgery (SSRF) via rewrites (CVE-2026-64645) and cache poisoning issues (CVE-2026-64647).
>
> **Remediation**: Upgrade immediately to a patched version (e.g., 12.3.5 or later). If upgrading isn't possible, configure a Web Application Firewall (WAF) to block external requests containing the x-middleware-subrequest header.



SSL/TLS Configuration Assessment :

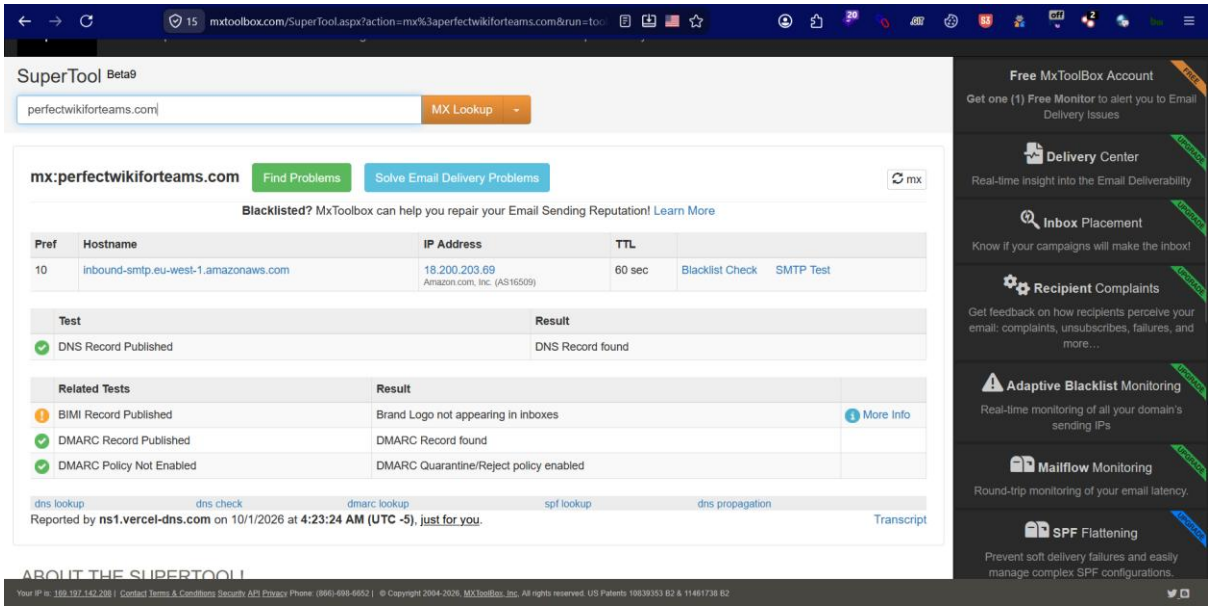
The SSL/TLS configuration of the web server was assessed using the Qualys SSL Labs online testing tool. The assessment returned an overall grade of A+, indicating a highly secure and modern implementation.



Email Security :

The email authentication mechanisms for the domain were assessed using MXToolbox. The following weaknesses were identified, which could allow an attacker to send spoofed emails impersonating the domain.

Impact:
An attacker could send phishing emails that appear to come from perfectwikiforteams.com. Because these emails would pass basic authentication checks, they are likely to land in the victim's inbox, increasing the risk of credential theft, malware distribution, or business email compromise (BEC).

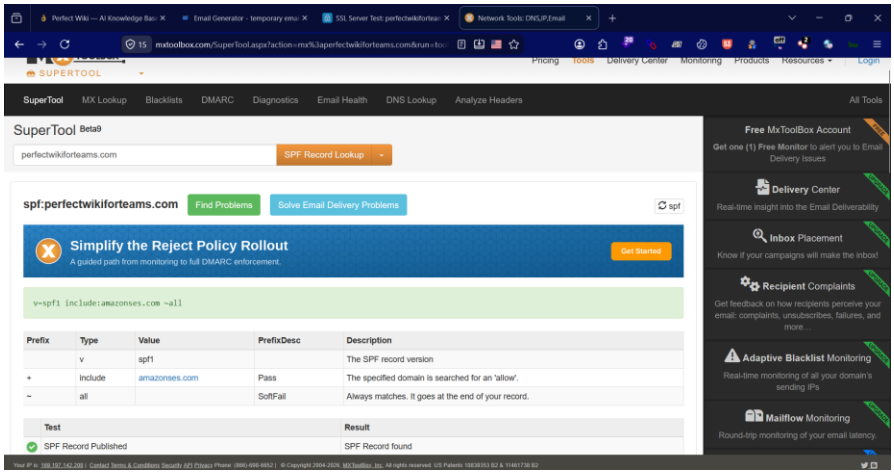


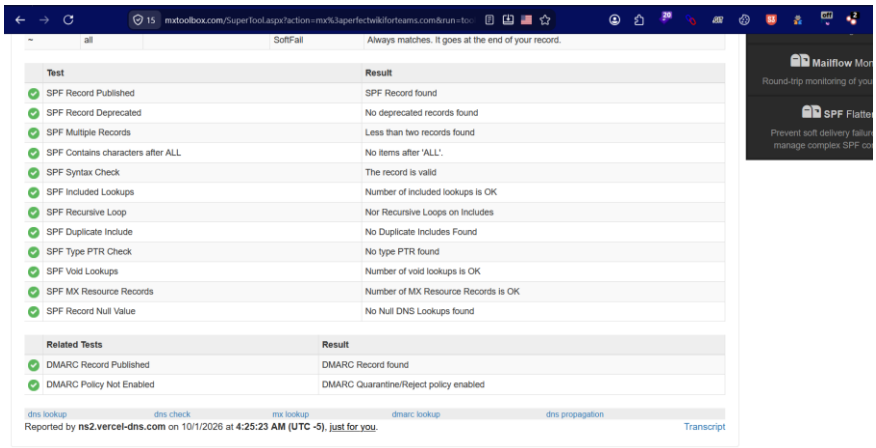
Weak SPF Configuration (SoftFail Policy)
Severity: Low
Affected Component: perfectwikiforteams.com (DNS TXT Record)

The SPF (Sender Policy Framework) record for the domain was assessed using MXToolbox. The record is configured with a ~all (SoftFail) qualifier instead of the recommended -all (HardFail) qualifier.

The current record is: v=spf1 include:amazonses.com ~all

This indicates that emails sent from unauthorized servers should be accepted but marked as suspicious, rather than being outright rejected.

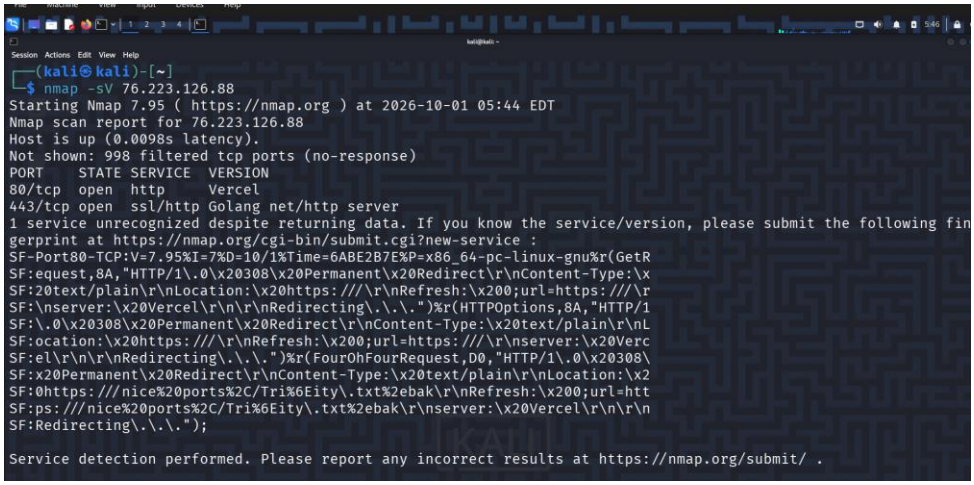




Open Ports / Network Service Exposure
Severity: Informational
Affected Component: 76.223.126.88 (perfectwikiforteams.com)

Description:
A TCP port scan was performed on the target server using Nmap (nmap -sV 76.223.126.88). The scan identified the following open ports and services exposed to the public internet. Out of 1,000 common ports scanned, 998 were filtered by a firewall, indicating a secure network perimeter.

No immediate security risk is presented. The server is properly configured to only expose the necessary ports for web traffic (HTTP/HTTPS). The firewall is actively filtering unauthorized ports, and Port 80 correctly redirects to the encrypted Port 443.



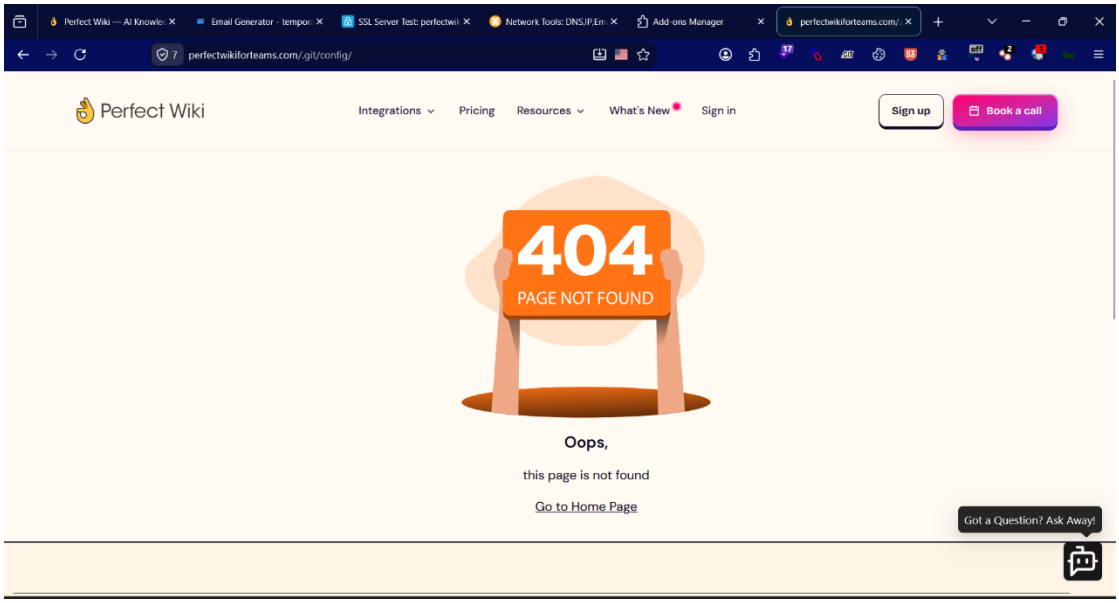
Exposed Git Repository (.git Directory)

Severity: Informational (Pass)

Affected Component: https://perfectwikiforteams.com/.git/

A check was performed to determine if the web application exposes its .git version control directory to the public internet.

Findings: The .git directory is not accessible. Attempts to access common Git paths (e.g., /.git/config, /.git/HEAD) returned a 404 Not Found response.



Conclusion

Based on the VAPT assessment of the perfectwikiforteams.com web application, several weaknesses were identified across HTTP methods, security headers, cookie security, server version disclosure, SSL/TLS configuration, email security, and open ports.

The most critical finding is the presence of an outdated Next.js framework (version 12.3.4), which is vulnerable to a critical authorization bypass (CVE-2025-29927). This flaw allows an attacker to bypass middleware security checks, potentially accessing protected pages or administrative panels without authentication. Immediate remediation is required to patch this vulnerability and prevent unauthorized access.

Additionally, the application lacks several critical HTTP security headers (resulting in a 'D' grade) and issues session cookies without the HttpOnly and Secure flags. These omissions weaken the application's client-side security posture, increasing the risk of Cross-Site Scripting (XSS), Clickjacking, and session hijacking. The weak SPF configuration (~all) also exposes the domain to potential email spoofing and phishing attacks.

Positively, the application demonstrates a strong foundational security posture. The SSL/TLS configuration received an A+ rating from SSL Labs, indicating robust encryption. The network perimeter is well-configured, with a firewall filtering 998 ports and exposing only the necessary web ports (80 and 443). Furthermore, the DMARC policy is enabled with a Quarantine/Reject policy, which significantly mitigates the risk of email spoofing.

It is highly recommended that the development team prioritize remediating the critical Next.js vulnerability immediately. Following this, implementing the missing security headers and cookie attributes will significantly bolster the application's resilience against client-side attacks. Regular security audits and dependency updates should be established to maintain a secure posture moving forward.